BTEUP EXAM NOTES | ENGLISH EDITION

Information Security

Unit 2: Network Protocol and Device Weaknesses and Security Solutions

About these notes

Part A explains every topic in very simple English with real-life examples, so a beginner can understand it from zero.
Part B gives important exam questions with full 5-mark model answers, ready to write in the exam.
At the end: quick revision sheet, common mistakes, and a self-test.

Syllabus covered (Unit 2)

Understanding security weaknesses in popular networking protocols: IP, TCP, UDP, RIP, OSPF, HTTP, SMTP, etc.; security weaknesses in common networking devices: Hub, switch, router, WiFi; Security solutions to mitigate security risk of networking protocols (IPSec, HTTPS, etc) and devices (VLAN, VPN, Ingress Filtering, etc).

Unit Overview and Contents

Simple idea: Networks were designed to be *fast and easy*, not *secure*. Old protocols and devices trust everyone, so attackers misuse them. This unit has 3 parts: (1) **weaknesses** of protocols, (2) **weaknesses** of devices, (3) **solutions** that fix these problems.

Topic	Exam importance	Where in notes
Weaknesses of IP, TCP, UDP	Very High	Part A: Topic 2 | Part B: Q1, Q11
Weaknesses of RIP, OSPF	High	Part A: Topic 2 | Part B: Q2
Weaknesses of HTTP, SMTP	Very High	Part A: Topic 2 | Part B: Q3
Hub, Switch, Router, WiFi weaknesses	Very High	Part A: Topic 3 | Part B: Q4, Q5, Q12
IPSec, HTTPS	Very High	Part A: Topic 4 | Part B: Q6, Q7
VLAN, VPN, Ingress Filtering	Very High	Part A: Topic 4 | Part B: Q8, Q9, Q10

Contents

Part A: Easy Explanation	Part B: Important Questions with Answers
Topic 1: Common network attacks Topic 2: Protocol weaknesses Topic 3: Device weaknesses Topic 4: Security solutions	Q1 IP, TCP, UDP weaknesses (Very Likely) Q2 RIP and OSPF weaknesses (Likely) Q3 HTTP and SMTP weaknesses (Very Likely) Q4 Hub, Switch, Router weaknesses (Very Likely) Q5 WiFi weaknesses and security (Very Likely) Q6 IPSec (Very Likely) Q7 HTTPS (Likely) Q8 VLAN (Likely) Q9 VPN (Likely) Q10 Ingress Filtering (Likely) Q11 SYN Flood attack (Possible) Q12 Hub vs Switch, MAC flooding, ARP spoofing (Possible)

How to study this unit (suggested time: 1 day)

1) Read Part A once to understand. 2) Read Part B answers and copy each answer on paper with the diagram. 3) Revise using the Quick Revision Sheet. 4) Attempt the Self-Test without looking.

PART A: Easy Explanation (Simple English)

Topic 1: Common Network Attacks (basics first)

Real-life example

A network is like a road. Anyone can stand on the road and see what is passing by, or pretend to be someone else. To understand protocol weaknesses, first know these common attacks.

Attack	Meaning	Simple example
Sniffing	Capturing data travelling on the network	Reading a password sent in plain text
Spoofing	Faking an identity (IP, MAC, email)	Sending a packet with a fake source IP
DoS / DDoS	Flooding a server so real users are denied service	SYN flood, UDP flood
Man-in-the-Middle (MITM)	Attacker sits between two parties, reads or changes data	Fake WiFi hotspot
Session Hijacking	Taking over someone's active session	Stealing a login cookie

Topic 2: Security Weaknesses in Networking Protocols

Why are protocols weak?

Most protocols (IP, TCP, UDP, HTTP, SMTP) were created in the 1970s-80s when the internet was small and trusted. They have **no authentication, no encryption and no integrity check** by default.

2(a) IP (Internet Protocol)

Real-life example

Postal letters have a sender address written by the sender himself. Anyone can write a false sender address. IP is the same.

- **No authentication:** source IP address can be faked (**IP spoofing**).
- **No encryption:** packets travel in clear text, so they can be **sniffed**.
- **Fragmentation attacks:** broken or overlapping fragments crash old systems (Teardrop, Ping of Death).
- **ICMP abuse:** Smurf attack (broadcast ping with fake source) and ping flood cause DoS.
- **Fix:** IPSec, ingress/egress filtering, firewall, disable directed broadcast.

2(b) TCP (Transmission Control Protocol)

Real-life example

TCP is like a phone call: first you say 'hello', the other says 'hello', you confirm. A fraudster can keep saying 'hello' to a shopkeeper with fake numbers until his phone is always busy.

- **SYN Flood:** attacker sends many SYN packets with fake IPs and never completes the 3-way handshake. The server's half-open connection table fills up and real users are denied.
- **Sequence number prediction / Session hijacking:** if sequence numbers are guessed, attacker can inject data or take over the connection.
- **RST injection:** a forged reset packet can cut a valid connection.
- **Port scanning:** open ports are discovered easily.
- **Fix:** SYN cookies, firewall, random initial sequence numbers, rate limiting, TLS.

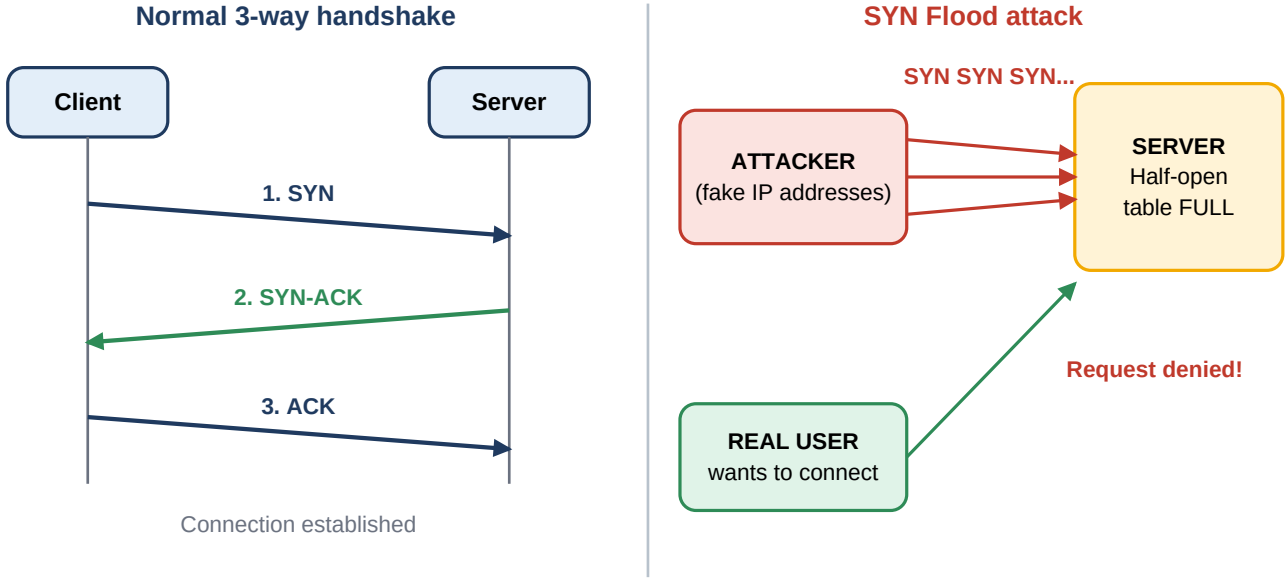


Figure 1: Normal TCP handshake and SYN Flood attack

2(c) UDP (User Datagram Protocol)

> **Real-life example**
> UDP is like throwing letters into a mailbox without asking for a receipt. It is fast, but nobody checks who sent it.

- **Connectionless:** no handshake, no sequence number, so spoofing is very easy.
- **UDP flood:** a huge number of UDP packets exhausts the server.
- **Amplification / Reflection DDoS:** small spoofed request to DNS/NTP servers gives a very large reply to the victim.
- No delivery guarantee and no built-in security.
- **Fix:** block unused ports, rate limiting, ingress filtering, DTLS.

2(d) RIP (Routing Information Protocol)

> **Real-life example**
> Imagine a traveller asking every passer-by for directions and believing everyone. A liar can send him to the wrong city. RIP routers trust every update in the same way.

- RIP is a **distance-vector** protocol that shares its routing table with neighbours regularly.
- **RIPv1 has no authentication.** Anyone can send a fake route update.
- **Route poisoning / false routes:** traffic is redirected to the attacker (sniffing) or dropped (black hole).
- Updates are broadcast, so they are easy to capture and fake.
- **Fix:** RIPv2 with MD5 authentication, passive interfaces, route filters.

2(e) OSPF (Open Shortest Path First)

- OSPF is a **link-state** protocol. Routers exchange **LSAs** (link state advertisements) to build the network map.
- If authentication is not configured (default is none), an attacker can inject **fake LSAs** and change the whole map.
- Results: traffic redirection (MITM), black hole, routing loops, DoS.
- Hello packets can be spoofed to create fake neighbours.
- **Fix:** OSPF authentication (MD5/SHA), passive interfaces, area design, route filtering.

2(f) HTTP (HyperText Transfer Protocol)

> **Real-life example**
> HTTP is like sending a postcard. Everyone who handles it can read it. Your password on the postcard is visible to all.

- **No encryption:** usernames, passwords and cookies travel in plain text and can be sniffed.
- **No server authentication:** you cannot be sure the website is genuine, so **MITM** and fake sites are possible.
- **Session hijacking:** stolen cookies let an attacker log in as you.
- **Data tampering:** content can be changed in transit.
- **Fix:** use **HTTPS**, secure cookies, HSTS, input validation.

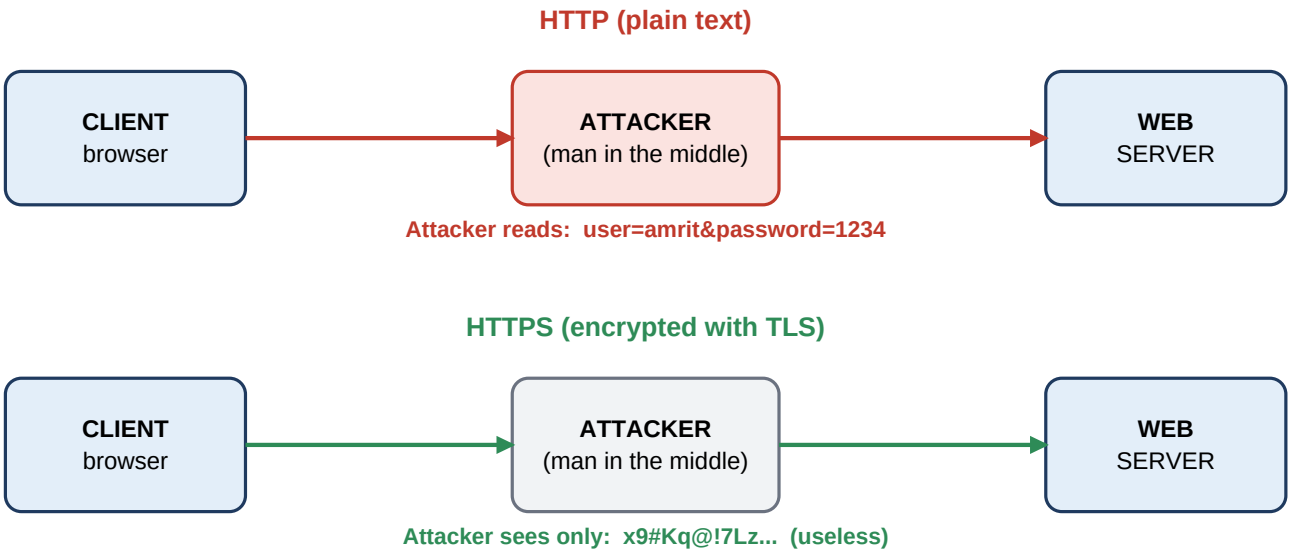


Figure 2: HTTP vs HTTPS when an attacker is in the middle

2(g) SMTP (Simple Mail Transfer Protocol)

> **Real-life example**
> Anyone can write any name in the 'From' field of an email, just like writing a fake name on a courier parcel. SMTP does not check it.

- **No sender authentication** by default: **email spoofing**, phishing and spam are easy.
- **Plain text:** emails and passwords can be sniffed.
- **Open relay:** a badly configured server forwards mail for anyone, so spammers misuse it.
- **Information leak:** VRFY and EXPN commands reveal valid user names.
- **Fix:** STARTTLS/SMTPS, SMTP AUTH, SPF, DKIM, DMARC, close open relay, spam filters.

Summary table: protocol weaknesses

Protocol	Main weakness	Attack	Solution
IP	No authentication	IP spoofing, Smurf	IPSec, ingress filtering
TCP	Handshake can be abused	SYN flood, hijacking	SYN cookies, firewall
UDP	Connectionless	UDP flood, amplification	Rate limit, block ports
RIP	No authentication (v1)	Fake route update	RIPv2 + MD5
OSPF	Fake LSAs accepted	Route injection	OSPF authentication
HTTP	Plain text	Sniffing, MITM	HTTPS (TLS)
SMTP	No sender check	Email spoofing, spam	SPF, DKIM, STARTTLS

Topic 3: Security Weaknesses in Networking Devices

3(a) Hub

> **Real-life example**
> A hub is like a person shouting a message in a room. Everyone in the room hears it, even if it was meant for one person.

- A hub works at Layer 1 and **broadcasts every packet to all ports**.
- Any connected PC with a sniffer (for example Wireshark) can read everyone's data.
- No filtering, no management, no security features. One shared collision domain.
- **Fix:** replace hubs with switches.

3(b) Switch

> **Real-life example**
> A switch is like a post office clerk who delivers each letter to the right house, using a list of addresses (MAC table). Attackers try to confuse this list.

- **MAC flooding:** thousands of fake MAC addresses fill the switch's CAM table. The switch then behaves like a hub and broadcasts, so the attacker can sniff.
- **ARP spoofing / poisoning:** the attacker sends fake ARP replies so that traffic goes through him (MITM).
- **VLAN hopping:** attacker reaches another VLAN by switch spoofing or double tagging.
- **STP attack:** fake BPDU makes the attacker the root bridge.
- **DHCP starvation / spoofing** and default passwords.
- **Fix:** port security, Dynamic ARP Inspection, DHCP snooping, BPDU guard, disable unused ports, change default passwords.

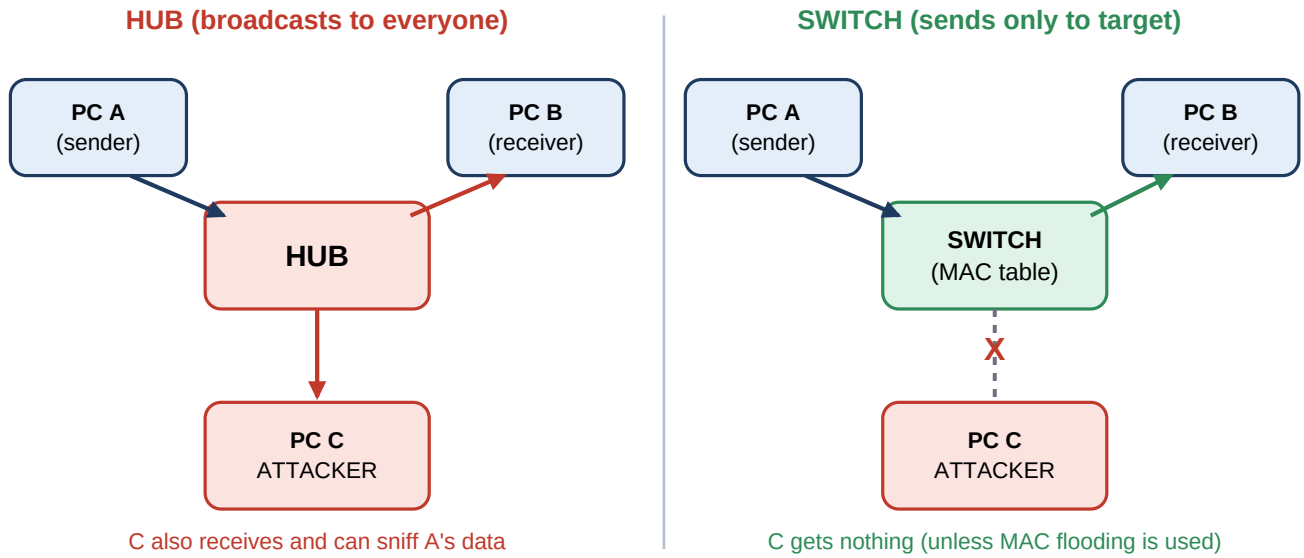


Figure 3: Hub vs Switch (sniffing)

3(c) Router

Real-life example

A router is the main gate of your network. If the gate has a weak lock or the key is 'admin/admin', thieves enter easily.

- **Default / weak passwords** on the admin panel.
- **Insecure management:** Telnet and HTTP management send passwords in plain text.
- **Outdated firmware** with known vulnerabilities.
- **Misconfigured ACLs** and unnecessary open services.
- **Routing attacks** (fake updates), source routing, ICMP redirects, and DoS floods.
- **Fix:** strong passwords, SSH instead of Telnet, firmware updates, ACLs, disable unused services, routing authentication.

3(d) WiFi (Wireless Network)

Real-life example

WiFi sends data through the air. It is like talking on a loudspeaker: anyone standing nearby can listen without any wire.

- **Eavesdropping:** radio signals pass through walls, so outsiders can capture traffic.
- **Weak encryption:** WEP is broken in minutes. WPA/WPA2 with a weak password can be cracked by dictionary attack.
- **Rogue AP / Evil Twin:** a fake access point with the same name tricks users to connect.
- **WPS PIN** weakness and **default admin password** of the router.
- **Deauthentication attack:** attacker disconnects users and captures the reconnect handshake.
- **Fix:** WPA3 or WPA2-AES, long passphrase, disable WPS, change default passwords, update firmware, WPA2-Enterprise (802.1X), separate guest network.

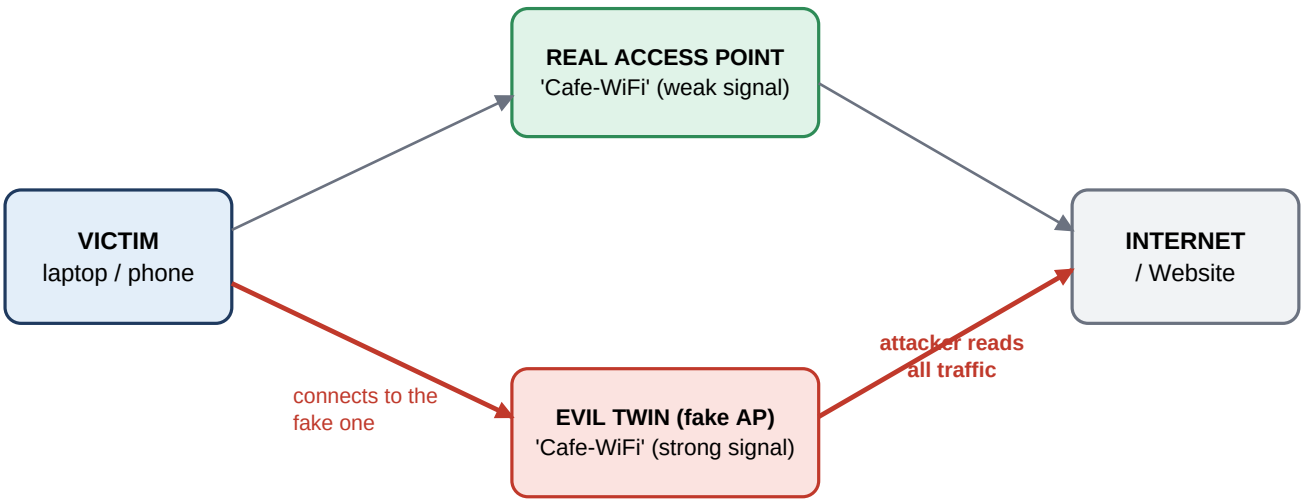


Figure 4: Evil Twin attack on WiFi

Topic 4: Security Solutions

Now that we know the problems, here are the main solutions for protocols (IPSec, HTTPS) and for devices/networks (VLAN, VPN, Ingress Filtering).

4(a) IPSec (IP Security)

Real-life example

Normal IP is a postcard. IPSec puts the letter in a **sealed, signed envelope**: nobody can read it, change it, or fake the sender.

Definition

IPSec is a suite of protocols that secures IP communication at the **network layer (Layer 3)** by providing confidentiality, integrity, authentication and anti-replay protection.

- **AH (Authentication Header):** gives authentication and integrity, but **no encryption**.
- **ESP (Encapsulating Security Payload):** gives **encryption** + authentication + integrity.
- **IKE (Internet Key Exchange):** sets up the keys and the **Security Association (SA)**.
- **Transport mode:** only data is protected (host to host).
- **Tunnel mode:** the whole original packet is protected and wrapped in a new IP header (gateway to gateway, used in VPN).

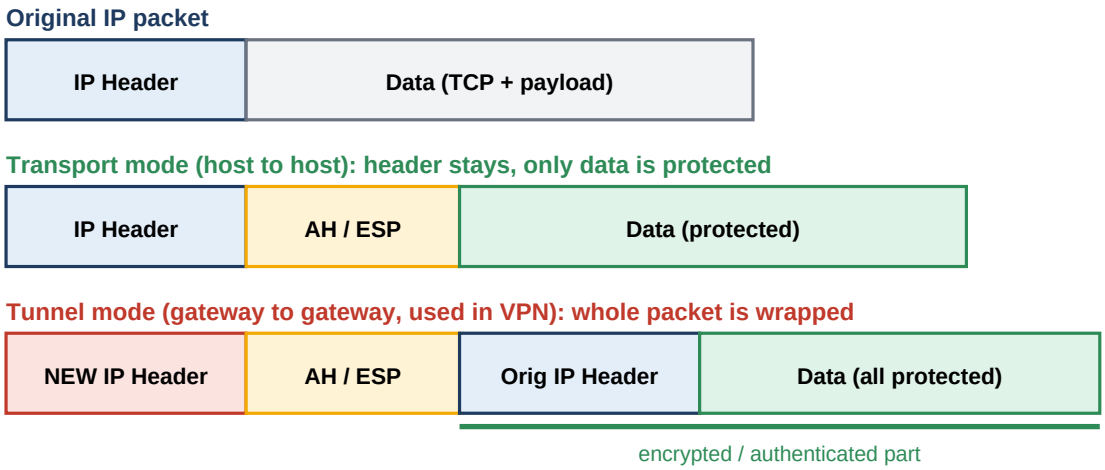


Figure 5: IPSec transport and tunnel modes

4(b) HTTPS (HTTP Secure)

Real-life example

HTTP is a postcard; HTTPS is a **locked box** that only the website can open. The browser's padlock shows that the website's identity is checked.

Definition

HTTPS is HTTP running over **SSL/TLS**. It uses port **443** and a digital certificate to give encryption, server authentication and integrity.

- **Step 1:** browser says hello and sends supported TLS versions.
- **Step 2:** server replies with its **digital certificate** (issued by a CA).
- **Step 3:** browser verifies the certificate.
- **Step 4:** a **session key** is shared securely using asymmetric cryptography.
- **Step 5:** all further data is encrypted with the fast **symmetric** session key.

4(c) VLAN (Virtual LAN)

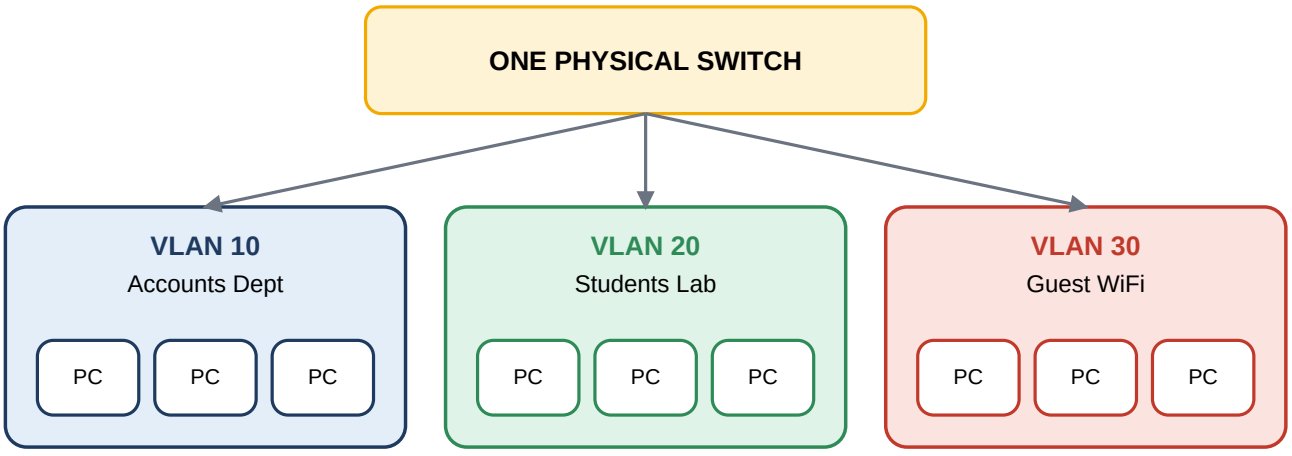
Real-life example

One big office hall can be divided with partitions: Accounts, Students, Guests. People in one cabin cannot hear the others. A VLAN does this inside a switch.

Definition

A **VLAN** is a logical group of devices on a switch that behave as if they are on a separate network, whatever their physical location. It uses **IEEE 802.1Q** tagging.

- Smaller **broadcast domain**, so less traffic to sniff.
- **Isolates** sensitive departments and guests from each other.
- Inter-VLAN traffic must pass a router or Layer-3 switch, where ACLs/firewall can be applied.
- Protect VLANs: disable DTP, change native VLAN, shut unused ports.



Different VLANs cannot talk to each other directly. Only a router / Layer-3 switch can connect them.

Figure 6: VLAN segmentation

4(d) VPN (Virtual Private Network)

Real-life example

A VPN is a **private, covered tunnel** built through a public road. Vehicles inside the tunnel cannot be seen or stopped by people outside.

Definition

A **VPN** creates a secure, encrypted tunnel over a public network such as the internet, so remote users or offices can connect safely to a private network.

- **Types:** Remote-access VPN (employee to office) and Site-to-site VPN (office to office).
- **Protocols:** IPSec, SSL/TLS VPN, OpenVPN, L2TP. (PPTP is old and weak.)
- Gives **confidentiality, integrity and authentication**.
- Protects users on public WiFi and hides data from sniffers.

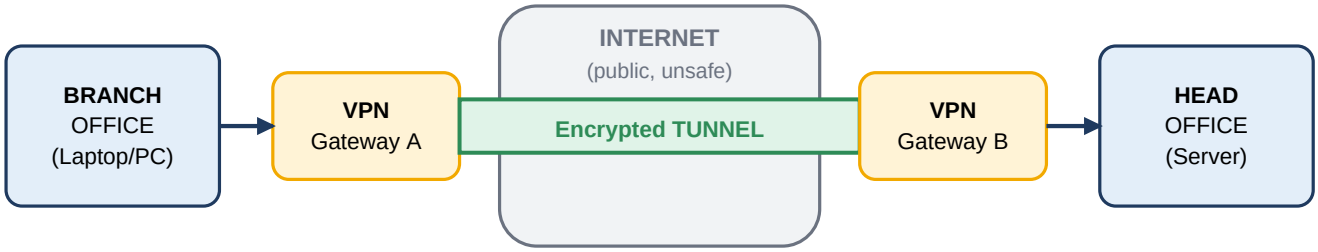


Figure 7: VPN tunnel

4(e) Ingress Filtering

Real-life example

At the main gate, a guard stops a stranger who says 'I am the owner of this house' while coming from outside. Ingress filtering is that guard for IP addresses.

Definition

Ingress filtering (BCP 38 / RFC 2827) is a technique where the edge router **drops incoming packets whose source IP address is not valid** for the network or interface they arrive from.

- It stops **IP spoofing** and reduces DDoS (including reflection attacks).
- Example: a packet from the internet claiming a private/internal address (10.x.x.x) is dropped.
- **Egress filtering** is the reverse: outgoing packets whose source IP does not belong to your network are blocked.
- Implemented using ACLs or **uRPF** (unicast Reverse Path Forwarding) on routers.

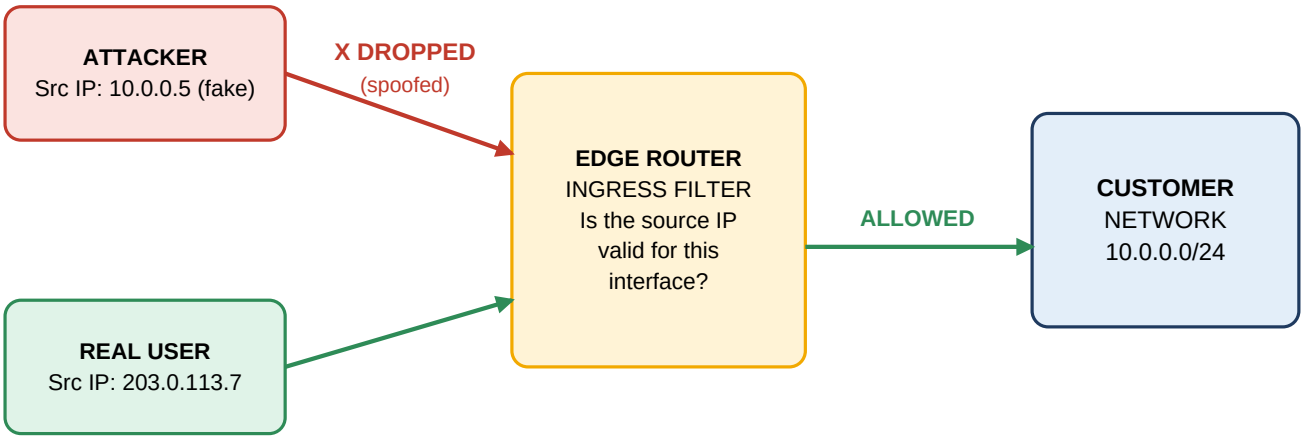


Figure 8: Ingress filtering at the edge router

PART B: Important Questions with Model Answers (English)

Priority: **Very Likely** = appears most often in BTEUP. **Likely** = good chance. **Possible** = can appear. Each answer follows the exam format: **Definition, Points, Diagram/Table, Conclusion**.

Q1. Explain the security weaknesses of IP, TCP and UDP. — VERY LIKELY

Definition / Introduction: IP, TCP and UDP are core internet protocols designed without security. Their main weaknesses are given below.

Points

- **IP:** no authentication, so source address can be faked (IP spoofing). No encryption, so packets can be sniffed. Fragmentation attacks (Teardrop, Ping of Death) and ICMP attacks (Smurf, ping flood) are possible.
- **TCP:** the 3-way handshake can be abused by SYN flood. Predictable sequence numbers allow session hijacking. A forged RST packet can break a connection. Port scanning is easy.
- **UDP:** connectionless with no handshake, so spoofing is very easy. UDP flood and amplification/reflection DDoS (DNS, NTP) are common. No delivery guarantee.
- **Solutions:** IPSec, ingress/egress filtering, firewalls, SYN cookies, rate limiting, blocking unused ports.

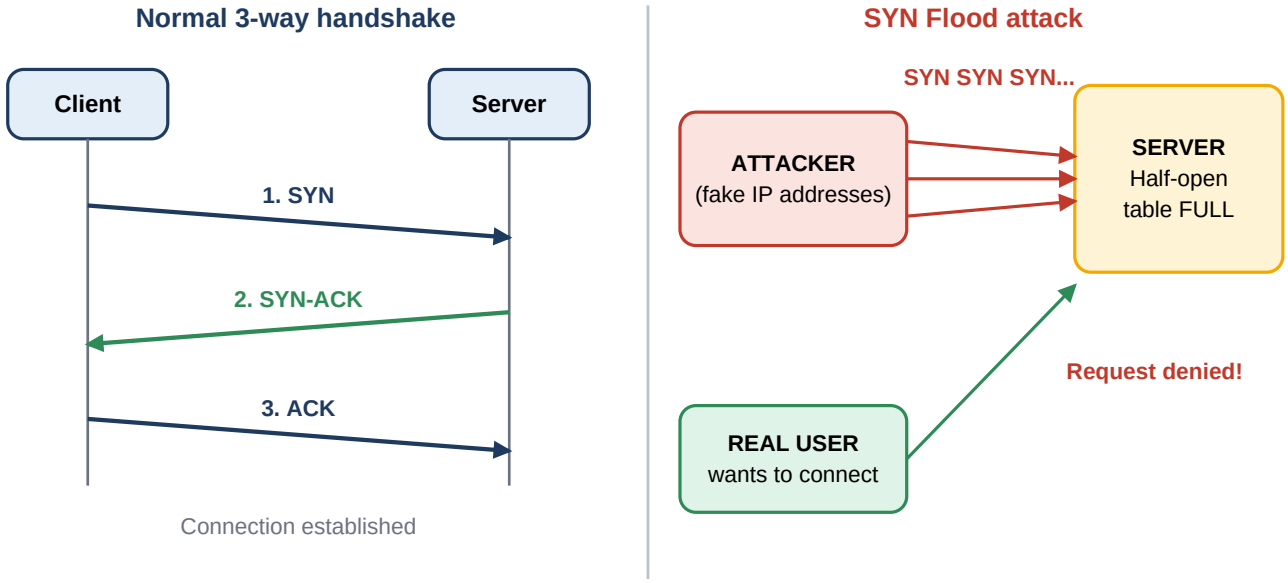


Figure: TCP handshake and SYN flood

Protocol	Weakness	Attack
IP	No authentication / encryption	IP spoofing, Smurf, Teardrop
TCP	Handshake abuse, predictable sequence	SYN flood, hijacking, RST injection
UDP	Connectionless	UDP flood, amplification

Conclusion: These protocols need added security such as IPSec, firewalls and filtering to be used safely.

Q2. Explain the security weaknesses of RIP and OSPF routing protocols. LIKELY

Definition / Introduction: RIP (distance-vector) and OSPF (link-state) are routing protocols that share route information between routers. They trust the updates they receive.

Points

- **RIP:** RIPv1 has no authentication, so anyone can send false route updates.
- RIP updates are broadcast regularly, so they are easy to capture and forge.
- **OSPF:** if authentication is not configured, fake LSAs and fake Hello packets are accepted.
- **Effects:** route poisoning, traffic redirection to the attacker (MITM), black hole, routing loops and DoS.
- **Solutions:** RIPv2 / OSPF authentication (MD5 or SHA), passive interfaces, route filtering, and secure router management.

Point	RIP	OSPF
Type	Distance-vector	Link-state
Default security	No authentication (v1)	No authentication by default
Attack	Fake route update	Fake LSA injection
Fix	RIPv2 + MD5	OSPF MD5/SHA authentication

Conclusion: Authenticating routing updates is essential to prevent attackers from controlling the traffic path.

Q3. Explain the security weaknesses of HTTP and SMTP. How can they be secured? VERY LIKELY

Definition / Introduction: HTTP is used for web browsing and SMTP for sending email. Both send data in plain text by default.

Points

- **HTTP weaknesses:** no encryption (passwords and cookies can be sniffed), no server authentication (MITM and fake sites), session hijacking and data tampering.
- **SMTP weaknesses:** no sender authentication (email spoofing, phishing, spam), plain text, open relay misuse and information leak through VRFY/EXPN.
- **Securing HTTP:** use HTTPS (TLS), secure cookies, HSTS and input validation.
- **Securing SMTP:** STARTTLS/SMTPS, SMTP AUTH, SPF, DKIM, DMARC, closing open relays and spam filters.

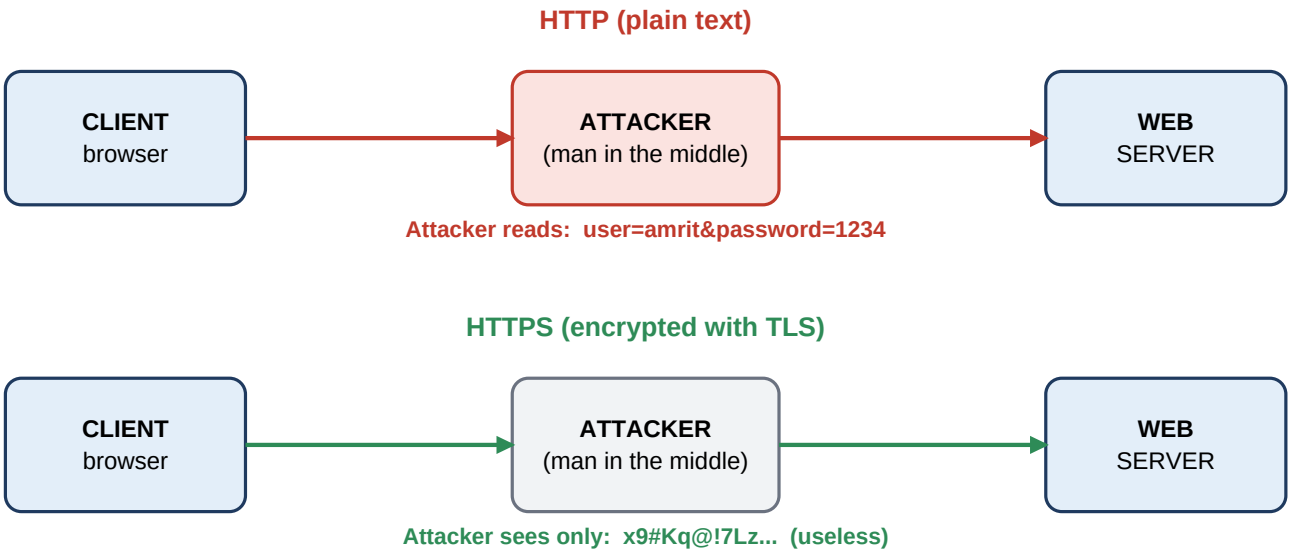


Figure: HTTP vs HTTPS under a man-in-the-middle attack

Conclusion: Using encrypted versions (HTTPS, SMTP over TLS) with authentication removes most of these weaknesses.

Q4. Explain the security weaknesses of Hub, Switch and Router. VERY LIKELY

Definition / Introduction: Hub, switch and router are the basic devices of a network. Each has its own security weaknesses.

Points

- **Hub:** broadcasts every packet to all ports, so any connected machine can sniff data. It has no filtering or management.
- **Switch:** MAC flooding, ARP spoofing, VLAN hopping, STP attacks, DHCP starvation and default passwords.
- **Router:** default/weak passwords, Telnet management, outdated firmware, misconfigured ACLs, routing protocol attacks and DoS.
- **Solutions:** replace hubs with switches, port security, DAI, DHCP snooping, strong passwords, SSH, firmware updates, ACLs.

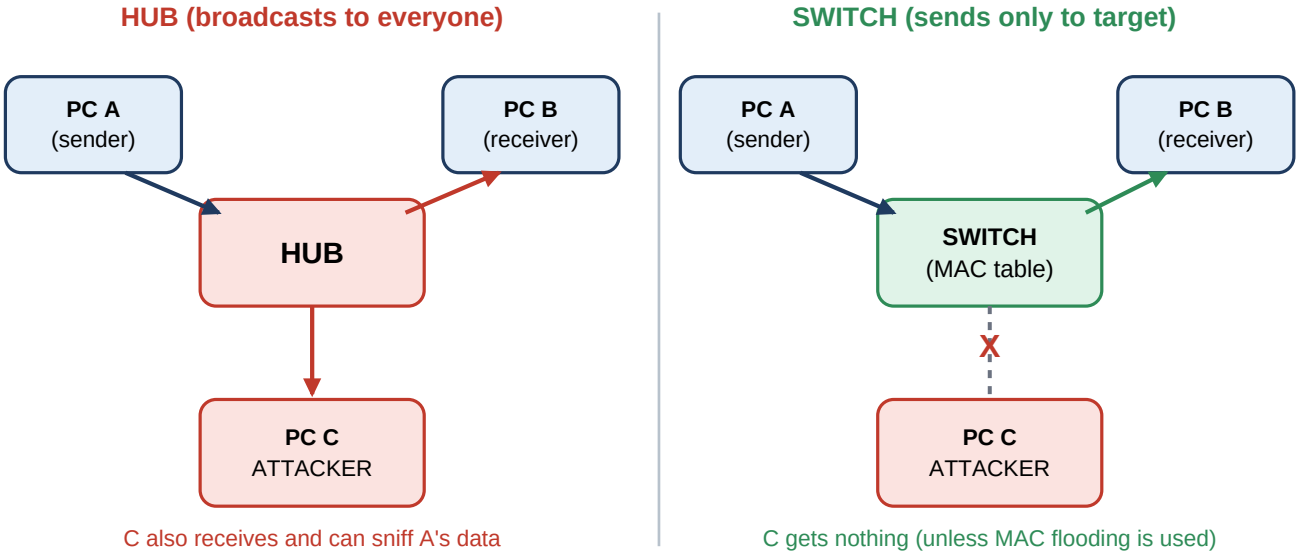


Figure: Hub broadcasts to all, switch sends only to the target

Device	Layer	Key weakness	Fix
Hub	1	Broadcast, sniffing	Use switch
Switch	2	MAC flooding, ARP spoofing	Port security, DAI
Router	3	Weak config, routing attacks	ACL, SSH, updates

Conclusion: Proper configuration and replacing old devices greatly reduce network-level attacks.

Q5. Explain the security weaknesses of WiFi and how to secure a wireless network. VERY LIKELY

Definition / Introduction: WiFi is a wireless LAN that sends data through radio waves. Because the medium is open air, it is easier to attack than a wired network.

Points

- **Eavesdropping:** signals can be captured from outside the building.
- **Weak encryption:** WEP is easily broken; WPA/WPA2 with weak passwords can be cracked.
- **Rogue AP / Evil Twin** and **MITM** attacks.
- **WPS PIN** weakness, default admin passwords and deauthentication attacks.
- **Security measures:** WPA3 or WPA2-AES, strong long passphrase, disable WPS, change default passwords, update firmware, use WPA2-Enterprise (802.1X), separate guest network, use VPN on public WiFi.

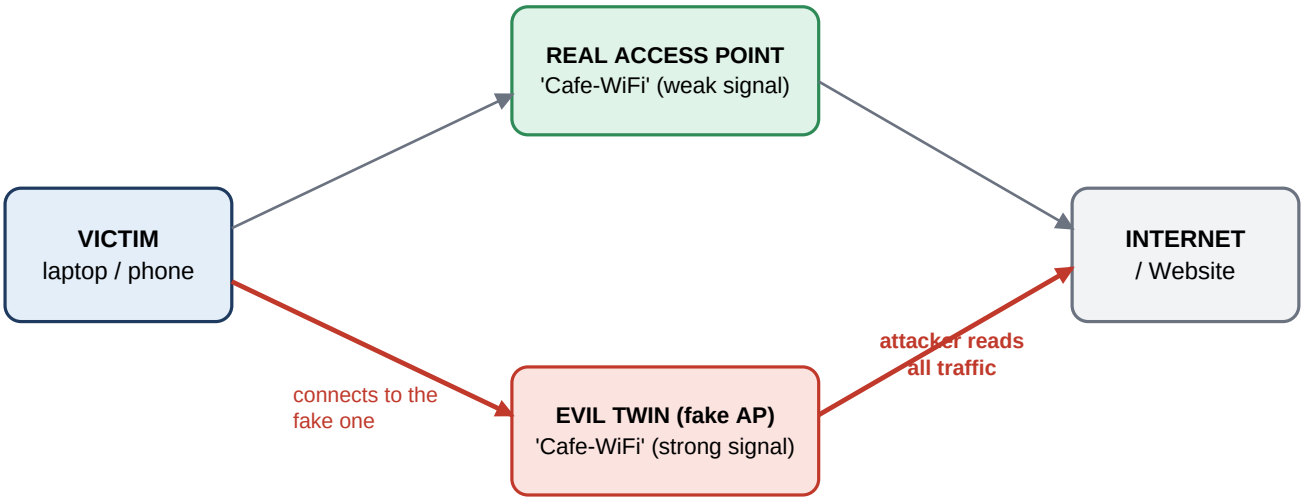


Figure: Evil Twin attack

Standard	Security level
WEP	Very weak, broken
WPA	Weak, outdated
WPA2 (AES)	Good
WPA3	Best (current)

Conclusion: A strong encryption standard with good password management keeps a wireless network safe.

Q6. What is IPSec? Explain its components and modes. VERY LIKELY

Definition / Introduction: IPSec (IP Security) is a suite of protocols that secures IP communication at the network layer by providing confidentiality, integrity, authentication and anti-replay protection.

Points

- **AH (Authentication Header):** authentication and integrity, no encryption.
- **ESP (Encapsulating Security Payload):** encryption, authentication and integrity.
- **IKE (Internet Key Exchange):** negotiates keys and creates a Security Association (SA).
- **Transport mode:** only the payload is protected; used between two hosts.
- **Tunnel mode:** the whole original packet is protected and a new IP header is added; used between gateways (VPN).

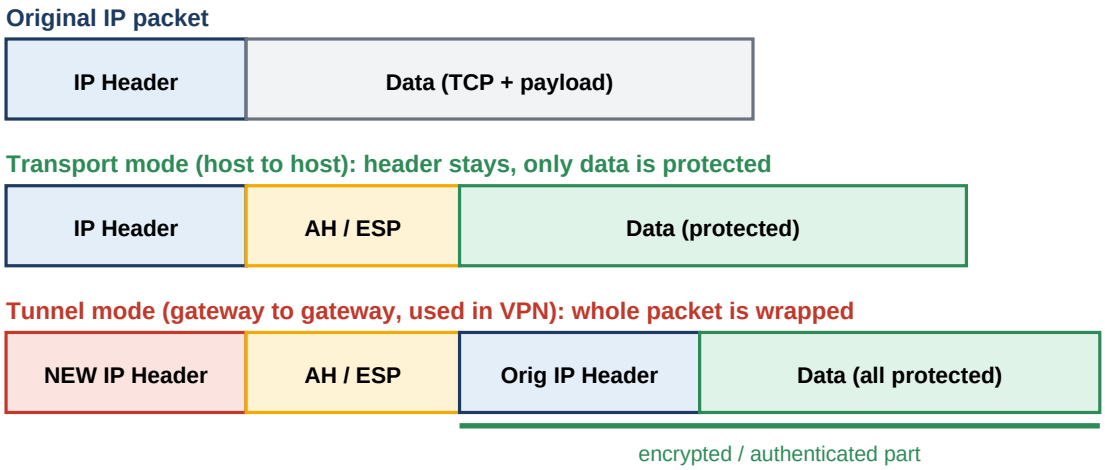


Figure: IPSec transport and tunnel modes

Point	AH	ESP
Encryption	No	Yes
Authentication / Integrity	Yes (whole packet)	Yes (payload)
Use	When only authenticity is needed	When secrecy is also needed

Conclusion: IPSec is the standard way to secure IP traffic and is the base of most VPNs.

Q7. What is HTTPS? How does it work? LIKELY

Definition / Introduction: HTTPS (HTTP Secure) is HTTP carried over SSL/TLS on port 443. It provides encryption, server authentication and data integrity.

Points

- The browser sends a hello with the supported TLS versions and ciphers.
- The server sends its **digital certificate** issued by a Certificate Authority (CA).
- The browser verifies the certificate (validity, domain, trusted CA).
- A **session key** is exchanged securely using asymmetric cryptography.
- Further data is encrypted with the symmetric session key, and hashes ensure integrity.
- **Benefits:** prevents sniffing, MITM and tampering. The padlock icon is shown in the browser.

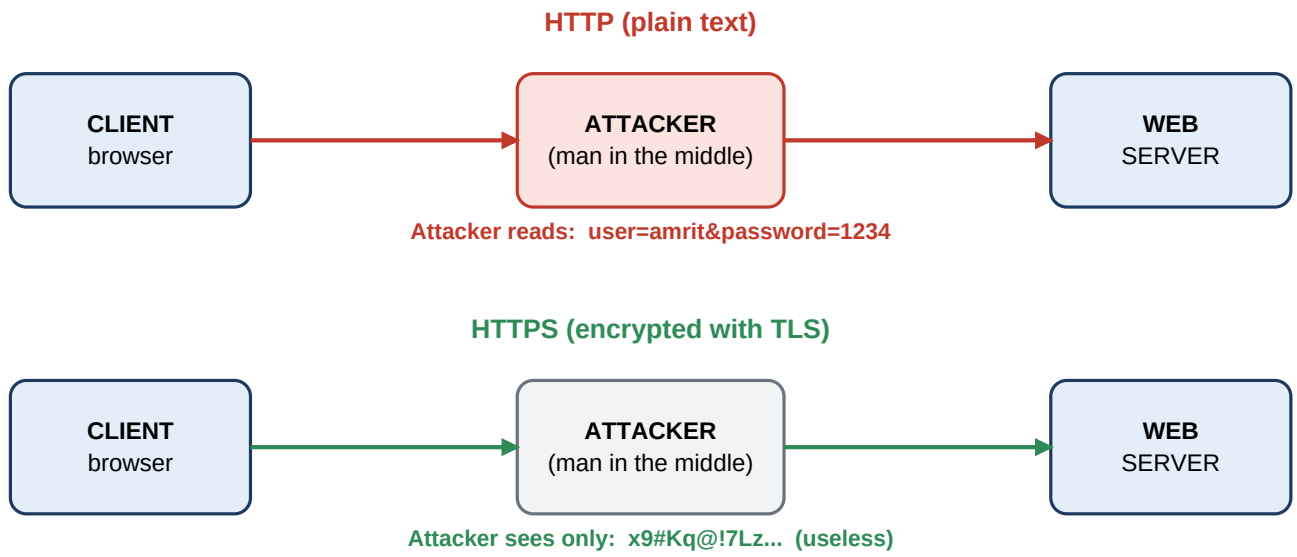


Figure: HTTPS protects data from a man-in-the-middle

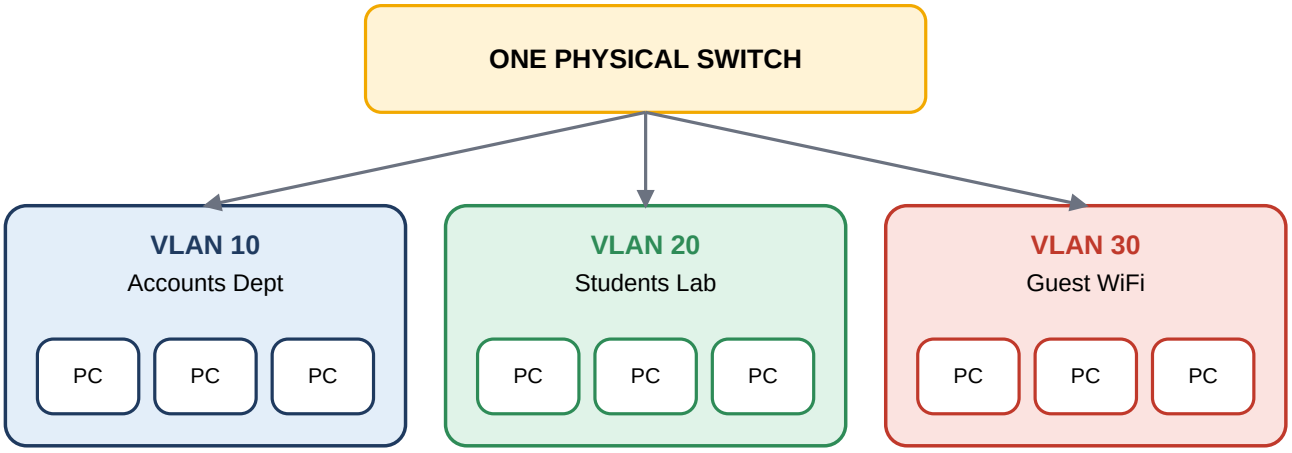
Conclusion: HTTPS is essential for any website handling passwords, payments or personal data.

Q8. What is VLAN? Explain its advantages. LIKELY

Definition / Introduction: A VLAN (Virtual LAN) is a logical group of devices on one or more switches that behave as a separate network, irrespective of physical location. It uses IEEE 802.1Q tagging.

Points

- **Security:** departments and guests are isolated, so sniffing and attacks are limited.
- **Smaller broadcast domain:** less traffic and better performance.
- **Flexibility:** users can be grouped by department, not by location.
- **Control:** communication between VLANs must pass a router or Layer-3 switch, where ACLs can be applied.
- **Risk:** VLAN hopping; prevent by disabling DTP, changing native VLAN and shutting unused ports.



Different VLANs cannot talk to each other directly. Only a router / Layer-3 switch can connect them.

Figure: VLAN segmentation

Conclusion: VLANs improve both security and performance of a LAN.

Q9. What is VPN? Explain its types and working. LIKELY

Definition / Introduction: A VPN (Virtual Private Network) creates an encrypted tunnel across a public network like the internet, giving private and secure communication.

Points

- **Working:** the VPN client/gateway authenticates the user, encrypts the data and sends it through a tunnel to the VPN server, which decrypts it.
- **Remote-access VPN:** a single user connects to the office network.
- **Site-to-site VPN:** two office networks are joined securely.
- **Protocols:** IPSec, SSL/TLS, OpenVPN, L2TP.
- **Benefits:** confidentiality, integrity, authentication, safe use of public WiFi, low cost compared to leased lines.

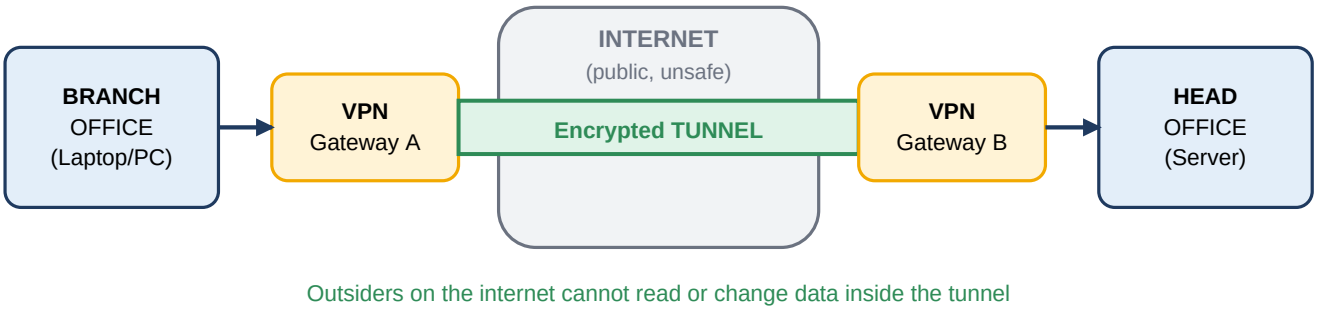


Figure: VPN tunnel across the internet

Conclusion: A VPN allows secure access to private resources over an insecure network.

Q10. What is Ingress Filtering? Why is it needed? LIKELY

Definition / Introduction: Ingress filtering (BCP 38 / RFC 2827) is a network security technique in which a router drops incoming packets whose source IP address is not valid for the interface they arrive on.

Points

- It prevents **IP spoofing**, where attackers hide their identity with a fake source address.
- It reduces **DDoS** and reflection/amplification attacks (Smurf, DNS amplification).
- **Example:** a packet arriving from the internet with source 10.0.0.5 (a private address) is dropped.
- **Egress filtering** is the reverse and blocks outgoing packets with a source address not belonging to your network.
- **Implementation:** ACLs or uRPF (Unicast Reverse Path Forwarding) on edge routers.

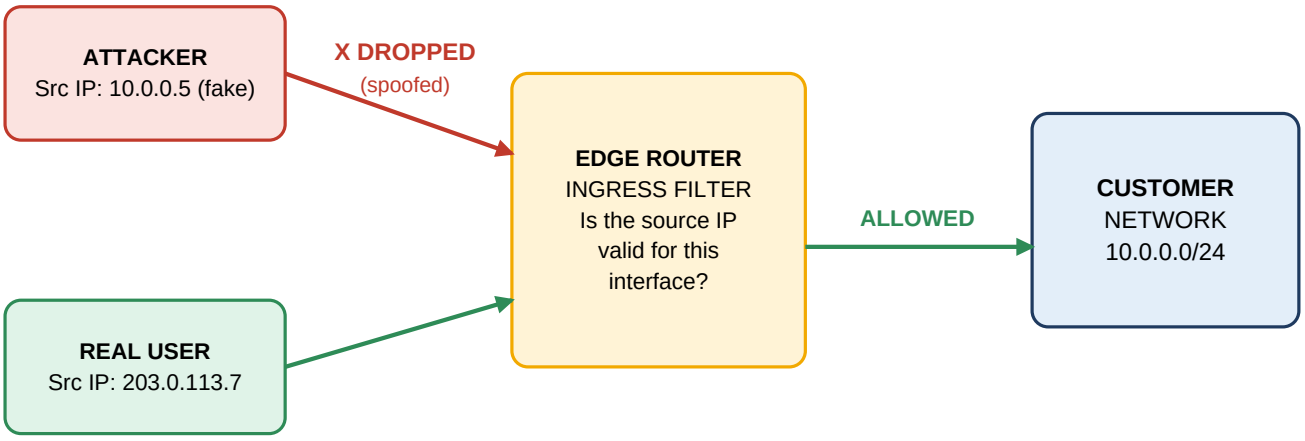


Figure: Ingress filtering at the edge router

Conclusion: If ISPs and organizations apply ingress filtering, spoofed-source attacks become much harder.

Q11. Explain the SYN Flood attack. POSSIBLE

Definition / Introduction: A SYN flood is a Denial-of-Service attack that abuses the TCP 3-way handshake to exhaust a server's resources.

Points

- Normal handshake: client sends SYN, server replies SYN-ACK, client sends ACK.
- In the attack, the attacker sends a huge number of SYN packets, usually with fake source IPs, and never sends the final ACK.
- The server keeps many **half-open connections** and its backlog queue becomes full.
- Real users cannot connect, so the service is denied.
- **Prevention:** SYN cookies, reduce SYN timeout, increase backlog, firewall/IPS rate limiting, ingress filtering.

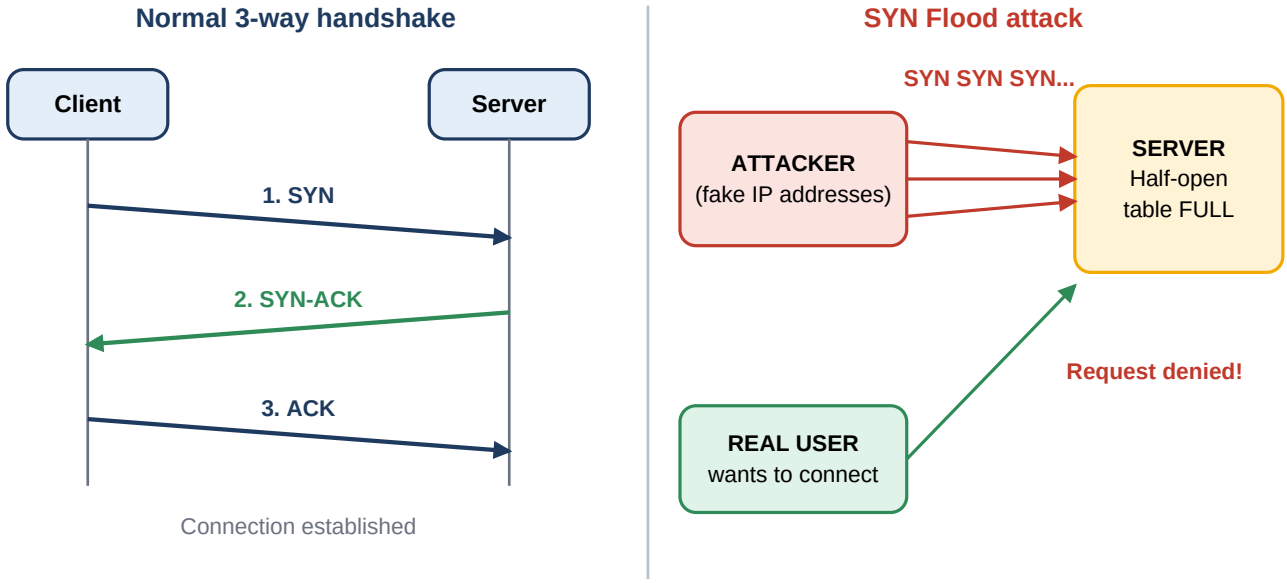


Figure: Normal handshake and SYN flood

Conclusion: SYN flood is simple but powerful, so servers must use SYN cookies and rate limiting.

Q12. Differentiate between Hub and Switch. Explain MAC flooding and ARP spoofing. POSSIBLE

Definition / Introduction: A hub is a simple Layer-1 device that repeats data to all ports; a switch is a Layer-2 device that forwards data only to the destination port using a MAC address table.

Points

- **MAC flooding:** the attacker floods the switch with fake MAC addresses until the CAM table is full. The switch then acts like a hub and the attacker can sniff. **Fix:** port security.
- **ARP spoofing:** the attacker sends fake ARP replies, linking his MAC address to another device's IP, so traffic passes through him (MITM). **Fix:** Dynamic ARP Inspection, static ARP entries.

Point	Hub	Switch
Layer	Layer 1 (Physical)	Layer 2 (Data link)
Data sending	Broadcast to all ports	Only to destination port
Intelligence	None	Uses MAC address table
Security	Very low, easy sniffing	Better, but MAC flooding / ARP spoofing possible
Collision domain	One for all	One per port

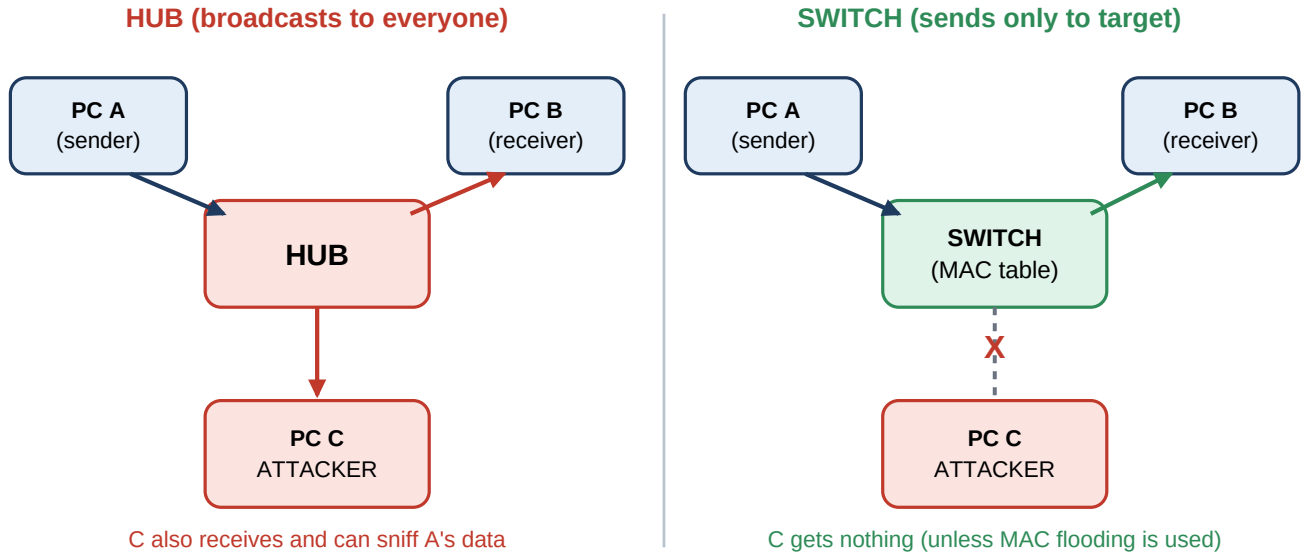


Figure: Hub vs Switch

Conclusion: Switches are more secure than hubs but must still be protected against MAC flooding and ARP spoofing.

Quick Revision Sheet (read the night before)

Term	Remember this
IP spoofing	Fake source IP. Fix: ingress filtering, IPSec
SYN flood	Many SYN, no final ACK, half-open table full. Fix: SYN cookies
Smurf	Broadcast ping with fake source (ICMP)
UDP amplification	Small spoofed request, huge reply to victim (DNS, NTP)
RIP	v1 no authentication. Fix: RIPv2 + MD5
OSPF	Fake LSA injection. Fix: OSPF authentication
HTTP vs HTTPS	Plain text vs TLS encrypted (port 80 vs 443)
SMTP	No sender check. Fix: SPF, DKIM, DMARC, STARTTLS
Hub	Layer 1, broadcast, easy sniffing
Switch attacks	MAC flooding, ARP spoofing, VLAN hopping, STP, DHCP
Switch fixes	Port security, DAI, DHCP snooping, BPDU guard
Router	Default password, Telnet, old firmware. Fix: SSH, ACL, updates
WiFi	WEP broken. Use WPA3 / WPA2-AES. Evil twin, WPS
IPSec	AH (no encryption), ESP (encryption), IKE (keys). Transport / Tunnel
HTTPS	HTTP + TLS, port 443, certificate from CA
VLAN	Logical LAN split, IEEE 802.1Q, smaller broadcast domain
VPN	Encrypted tunnel. Remote-access and Site-to-site
Ingress filtering	Drop incoming packets with invalid source IP (BCP 38)

Memory tricks

Protocol weakness: remember **'No A-E-I'** = No Authentication, No Encryption, No Integrity.
Switch attacks: M-A-V-S-D = MAC flooding, ARP spoofing, VLAN hopping, STP, DHCP.
IPSec: AH = Authenticate only, ESP = Encrypt too.
Ingress vs Egress: Ingress = coming **in**, Egress = going **out**.

Common Mistakes Students Make

- Confusing **AH** and **ESP**. Only ESP encrypts.
- Writing that HTTPS and HTTP are different protocols. HTTPS is **HTTP over TLS/SSL**.
- Mixing up **ingress** (incoming) and **egress** (outgoing) filtering.
- Saying a switch is completely safe. It can still face MAC flooding and ARP spoofing.
- Forgetting the **solution** after writing a weakness. Always add a fix.
- Not drawing diagrams (SYN flood, IPSec modes, VPN, VLAN).

Self-Test (answer without looking, 5 marks each)

- Explain the SYN flood attack with a diagram.
- Write the weaknesses of HTTP and SMTP with one solution for each.
- Explain MAC flooding and ARP spoofing.
- Differentiate between AH and ESP. What are transport and tunnel modes?
- What is ingress filtering? Give an example.

Self-Test Answers (check after writing)

1. Attacker sends many SYN packets with fake IPs and never sends the final ACK. The server's half-open table fills and real users are denied. Fix: SYN cookies, rate limiting. Draw the SYN flood figure.

2. HTTP: plain text, sniffing and MITM, fix with HTTPS. SMTP: no sender authentication (email spoofing), plain text, fix with SPF/DKIM or STARTTLS.

3. MAC flooding fills the switch CAM table with fake MACs so it acts like a hub (fix: port security). ARP spoofing sends fake ARP replies so traffic passes through the attacker (fix: DAI).

4. AH gives authentication and integrity but no encryption; ESP gives encryption too. Transport mode protects only the payload (host to host); tunnel mode protects the whole packet and adds a new IP header (gateway to gateway, VPN).

5. The edge router drops incoming packets whose source IP is not valid for that interface, stopping IP spoofing. Example: a packet from the internet with source 10.0.0.5 (private address) is dropped.

> **Done with Unit 2!**
> If you scored 4 out of 5 or more, move to **Unit 3**. If not, re-read the topics you missed in Part A.